

INCIDENT REPORT 4

=====

Report ID: IR-004
Incident Name: Brute Force SSH on Linux
Date/Time: May 5, 2026, around 09:24–09:25
Severity: HIGH
Status: Resolved (lab environment)
Environment: Wazuh 4.7.5 Mini SOC Home Lab
Analyst: Jazz

1. EXECUTIVE SUMMARY

At approximately May 5, 2026 around 09:24–09:25, Wazuh SIEM detected repeated SSH authentication failures in the Linux environment. The activity involved invalid usernames and incorrect password attempts against a Linux SSH service.

This simulated a brute-force SSH attack, where an attacker attempts multiple username/password combinations to gain unauthorized access. Wazuh generated alerts including “sshd: Attempt to login using a non-existent user,” “PAM: User login failed,” and “User missed the password more than one time.”

The incident maps to MITRE ATT&CK T1110.001 — Password Guessing under the Credential Access tactic.

2. TIMELINE

May 5, 2026 around 09:24:50

First visible SSH authentication failure appeared in Wazuh Security Events.

May 5, 2026 around 09:25:05

Additional SSH login attempts were generated using invalid usernames and wrong passwords.

May 5, 2026 around 09:25:11

Wazuh generated repeated “sshd: Attempt to login using a non-existent user” alerts.

May 5, 2026 around 09:25:13

Wazuh generated “User missed the password more than one time.”

May 5, 2026 around 09:25

The alert appeared in the Wazuh dashboard and was reviewed.

May 5, 2026 after investigation

The event was confirmed as a true positive lab simulation.

3. DETECTION SOURCE

Tool: Wazuh SIEM/XDR
Wazuh Version: 4.7.5
Detection Area: Linux SSH authentication monitoring
Log Source: /var/log/auth.log and Wazuh Security Events
Protocol: SSH
Destination Port: 22
Affected Agents: Wazuh-Server and/or ubuntu-endpoint depending on target

Observed Wazuh Rule IDs:

- 5710 — sshd: Attempt to login using a non-existent user
- 5503 — PAM: User login failed
- 2502 — User missed the password more than one time

Severity:

- Rule 5710: Level 5
- Rule 5503: Level 5
- Rule 2502: Level 10

Target usernames:

- wronguser
- enduser

4. MITRE ATT&CK MAPPING

Tactic: Credential Access
Technique: Brute Force
Sub-technique: T1110.001 — Password Guessing

Explanation:

The activity maps to Credential Access because the attacker attempted to guess SSH credentials. SSH brute force is a common method used to gain access to Linux servers.

Potential attacker next steps if successful:

- Log in to the Linux host
- Run reconnaissance commands
- Attempt sudo privilege escalation

- Access sensitive files
- Install persistence
- Move laterally to another system

5. INVESTIGATION FINDINGS

Source:

The source IP should be taken from the expanded Wazuh alert or /var/log/auth.log.

Target:

Linux SSH service on the monitored lab endpoint.

Observed behavior:

- Multiple SSH login attempts occurred.
- Invalid usernames were used.
- Wrong passwords were entered.
- Wazuh generated SSH/PAM authentication alerts.
- The event appeared in Security Events.
- The event mapped to T1110.001 Password Guessing.
- No successful login was confirmed after the failed attempts.

Evidence reviewed:

- Wazuh Security Events showing SSH failed login alerts
- Expanded Wazuh alert details
- Ubuntu auth.log terminal output
- Hydra SSH test output
- MITRE ATT&CK dashboard showing Password Guessing

Account locked:

No. Account lockout or fail2ban blocking was not configured during the test.

Compromise confirmed:

No. This was a controlled simulation.

6. RISK ASSESSMENT

Risk: HIGH

Reason:

SSH brute force is high risk because a successful login could give the attacker command-line access to the Linux system. Once inside, the attacker may attempt sudo privilege escalation, persistence, and lateral movement.

The risk is especially high if:

- SSH password authentication is enabled
- Weak passwords are used
- SSH is exposed to the internet
- No lockout/rate limiting is configured
- The same source IP later logs in successfully

In this lab, the risk was controlled because no successful compromise occurred.

7. VERDICT

Verdict: TRUE POSITIVE — Lab Simulation

The alert is a true positive because the SSH authentication failures actually occurred and Wazuh detected them. The activity was intentionally generated in the lab.

In production, repeated SSH failures should be treated as suspicious until the source and intent are confirmed.

8. RESPONSE ACTIONS TAKEN

1. Reviewed Wazuh Security Events.
2. Identified SSH authentication alerts.
3. Verified rule IDs 5710, 5503, and 2502.
4. Reviewed `/var/log/auth.log` evidence.
5. Confirmed invalid username and wrong password activity.
6. Confirmed MITRE mapping to T1110.001.
7. Confirmed no successful login occurred.
8. Documented the incident.

9. RECOMMENDATIONS

1. Disable password-based SSH login.
2. Use SSH key authentication.
3. Install and configure fail2ban.
4. Restrict SSH access to trusted IPs.

5. Monitor for successful logins after failed attempts.
6. Alert on repeated invalid usernames.
7. Enforce strong passwords.
8. Disable root SSH login.
9. Review `/var/log/auth.log` regularly.
10. Enable Wazuh Active Response to block repeated malicious source IPs.

10. FINAL ANALYST NOTE

This incident demonstrates Wazuh's ability to detect Linux SSH brute-force behavior using `/var/log/auth.log`. The lab confirmed that Wazuh can identify invalid users, repeated failed logins, and password-guessing behavior, then map the activity to MITRE ATT&CK.